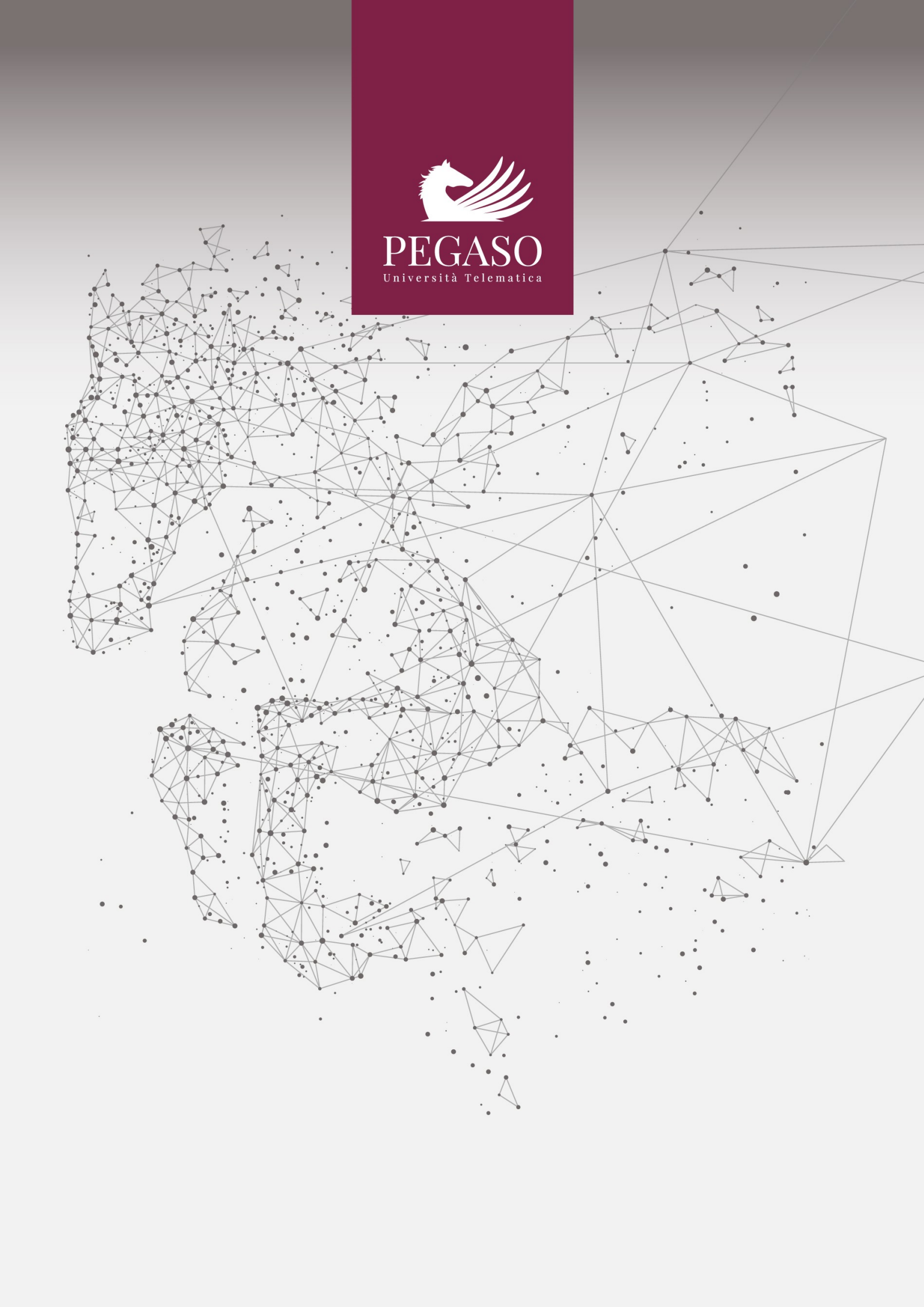

PEGASO
Università Telematica

*Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).*

# Indice

**1. L'ARCHITETTURA SSL ..... 3**
**2. SSL RECORD PROTOCOL ..... 5**
**3. I PROTOCOLLI SSL CHANGE CIPHER SPEC E ALERT ..... 7**
**4. IL PROTOCOLLO SSL HANDSHAKE ..... 8**
**BIBLIOGRAFIA ..... 10**

PEGASO
Università Telematica

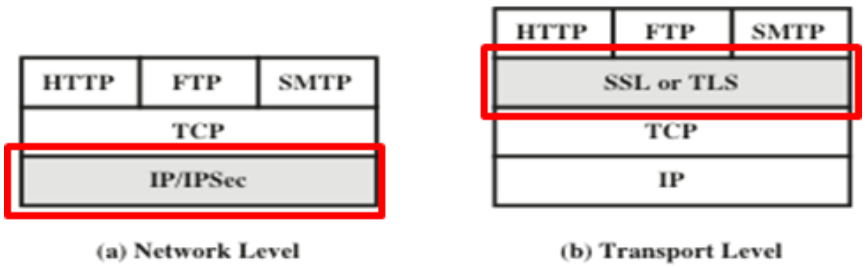
*Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).*

# 1. L'architettura SSL

La sicurezza web può essere offerta in varie modalità e con differenti meccanismi e soprattutto in differenti posizioni nell'ambito dello stack di protocolli TCP/IP.

- *IPSec* opera a livello di rete e si presenta trasparente sia a gli utenti sia alle applicazioni
- Una soluzione diversa consiste nell'implementare la sicurezza a livello trasporto ovvero appena sopra il protocollo TCP come in **SSL/TLS**

Nella figura sottostante sono evidenziate queste due diverse implementazioni dei meccanismi di sicurezza: a livello di rete (IPSec, a sinistra in figura) e a livello trasporto ovvero sopra allo strato TCP (SSL/TLS a destra in figura).

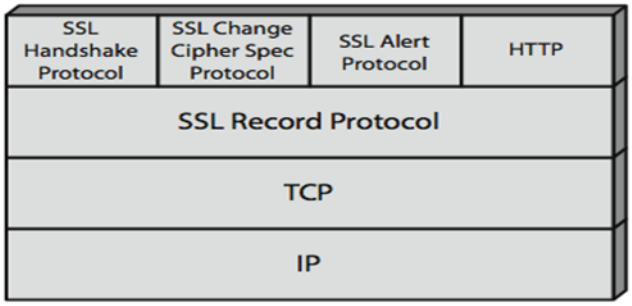



**SSL (Secure Socket Layer)** è stato sviluppato da Netscape e dopo vari processi di revisione si è arrivati ad una versione (v3) standard; infine (con alcune differenze) è diventato definitivamente standard per Internet con il nome di **TLS (Transport Layer Security)**.

**SSL** è un insieme di protocolli crittografici che permettono una comunicazione sicura end-to-end su reti TCP/IP (Internet); HTTPS è un esempio di applicazione di SSL/TLS

*Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).*

SSL è costituito da due strati di protocolli (vedi figura):




- *SSL Record Protocol* che offre i servizi di sicurezza di base per i protocolli di livello superiore (può operare direttamente con HTTP)
- (SSL) *Handshake Protocol*, *Change Cipher Spec Protocol* e *Alert Protocol* sono invece tre protocolli di più alto livello

In SSL esistono inoltre due concetti molto importanti che sono la *connessione SSL* e la *sessione SSL* (lo stato di entrambe è definito da una serie di parametri identificati nelle specifiche SSL):

- *Connessione SSL*: è una forma di trasporto che fornisce un determinato servizio; le connessioni sono transitorie e ogni connessione è associata ad una sola sessione
- *Sessione SSL*: è un'associazione fra client e server. Le sessioni vengono definite dal protocollo *Handshake* e definiscono un insieme di parametri di sicurezza crittografica che possono essere condivisi fra più connessioni (si evita di rifare ogni volta la fase di negoziazione!)

PEGASO
Università Telematica

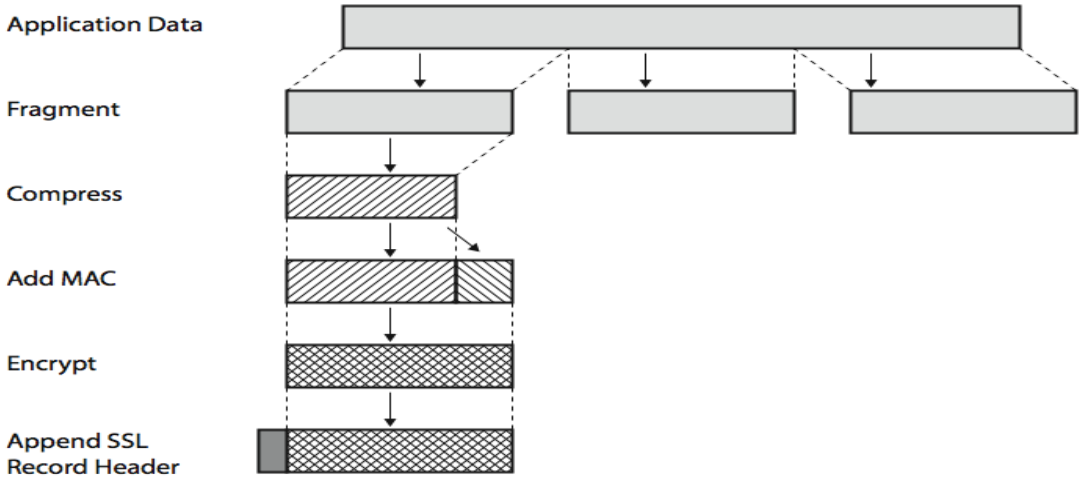
*Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).*

# 2. SSL Record Protocol

Il **protocollo SSL Record** fornisce due servizi per le connessioni SSL:

- Servizio di **integrità del messaggio**: basato su un codice MAC (simile ad HMAC ma con padding diverso) con una chiave segreta condivisa tramite il protocollo *Handshake*
- Servizio di **segretezza**: realizzato tramite cifratura simmetrica la cui chiave segreta condivisa è definita tramite il protocollo *Handshake*; il messaggio è compresso prima di essere cifrato (AES, DES, IDEA, 3DES, ecc.)

Nella figura qui sotto sono rappresentati i vari passaggi che costituiscono il protocollo.




Il protocollo SSL Record, come si vede bene in figura, opera sul messaggio da trasmettere frammentandolo generalmente in blocchi di $2^{14}$ byte (16384 byte) per poi applicare una compressione (senza perdita di informazione)

Successivamente si genera un codice MAC, in maniera molto simile a quanto si fa in HMAC usando una chiave segreta; il MAC viene aggiunto al messaggio compresso e il tutto viene cifrato in crittografia simmetrica.

È importante notare che il codice MAC viene calcolato prima della crittografia e poi viene successivamente cifrato insieme al testo in chiaro semplice o compresso!

PEGASO
Università Telematica

*Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).*

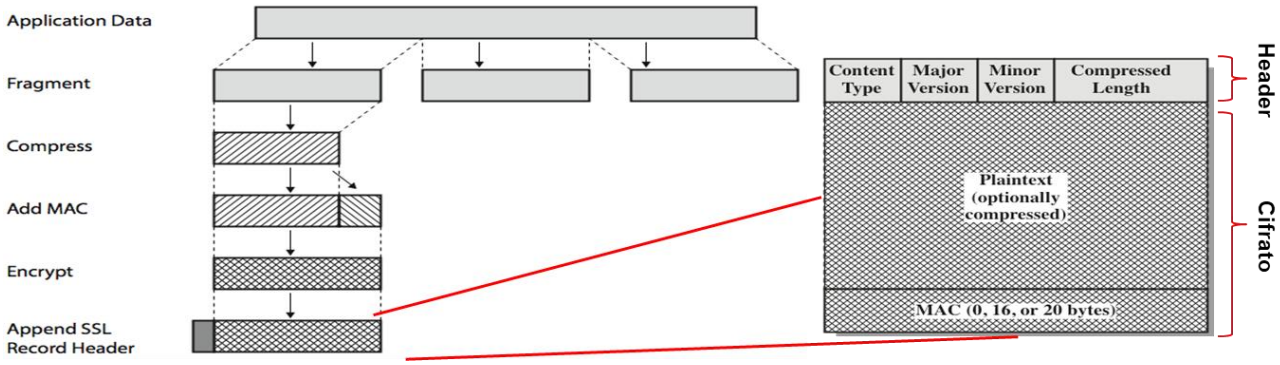
Per la crittografia simmetrica si possono usare algoritmi a blocchi (AES, IDEA, 3DES) o a flussi (RC4-128). Nel caso di cifratura a blocchi, per avere un numero intero di blocchi in relazione alla dimensione del blocco stesso, possono essere aggiunti dei byte di riempimento la cui lunghezza deve essere dichiarata.

Esempio: supponiamo di usare DES (lunghezza blocco 8 byte)

- Testo in chiaro o compresso di 58 byte
- Codice MAC generato con SHA-1 (160 bit = 20 byte)
- 1 byte per la padding.length

Il tutto fa 79 byte, dobbiamo quindi aggiungere solo 1 byte di padding per arrivare ad un multiplo intero di 8.

In ultimo si aggiunge l'intestazione iniziale costituita da 4 campi come evidenziato nella figura successiva.




*Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).*

# 3. I protocolli SSL Change Cipher Spec e Alert

Il **protocollo SSL Change Cipher Spec** è uno dei 3 protocolli di livello superiore che usano SSL Record Protocol:

- è il più semplice di tutti
- è costituito da un singolo byte impostato a 1
- indica la richiesta, da parte del mittente, di cambiare la cifratura da usare per l'attuale connessione

Il **protocollo SSL Alert** invece serve per trasmettere messaggi di allarmi SSL all'entità peer:

- è costituito da due byte
  - il primo specifica il livello di severità dell'alert che può essere *warning* o *fatal* (in questo caso SSL chiude immediatamente la connessione)
  - il secondo identifica invece la tipologia di alert

Le tipologie di **SSL Alert** possono essere per i due livelli di severità:

- *warning*: close notify, no certificate, bad certificate, unsupported certificate, certificate revoked, certificate expired, certificate unknown
- *fatal*: unexpected message, bad record mac, decompression failure, handshake failure, illegal parameter

PEGASO
Università Telematica

*Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).*

# 4. Il protocollo SSL Handshake

Il **protocollo SSL Handshake** costituisce la parte più complessa di SSL.

Esso consente ad un server e ad un client di:

- autenticarsi vicendevolmente
- negoziare gli algoritmi per la crittografia e il codice MAC
- negoziare le chiavi crittografiche da usare

Il protocollo SSL Handshake è articolato su una serie di messaggi la cui struttura è definita da 3 campi

- *Tipo (1 byte)*: indica il tipo di messaggio (ce ne sono 10, vedi tabella in figura)
- *Lunghezza (3 byte)*: indica la lunghezza del messaggio in byte
- *Contenuto (≥0 byte)*: indica i parametri associati al messaggio

| Tipi di messaggio | Parametri |
|---|---|
| hello_request | null |
| client_hello | version, random, session id, cipher suite, compression method |
| server_hello | version, random, session id, cipher suite, compression method |
| certificate | chain of X.509v3 certificates |
| server_key_exchange | parameters, signature |
| certificate_request | type, authorities |
| server_done | null |
| certificate_verify | signature |
| client_key_exchange | parameters, signature |
| finished | hash value |

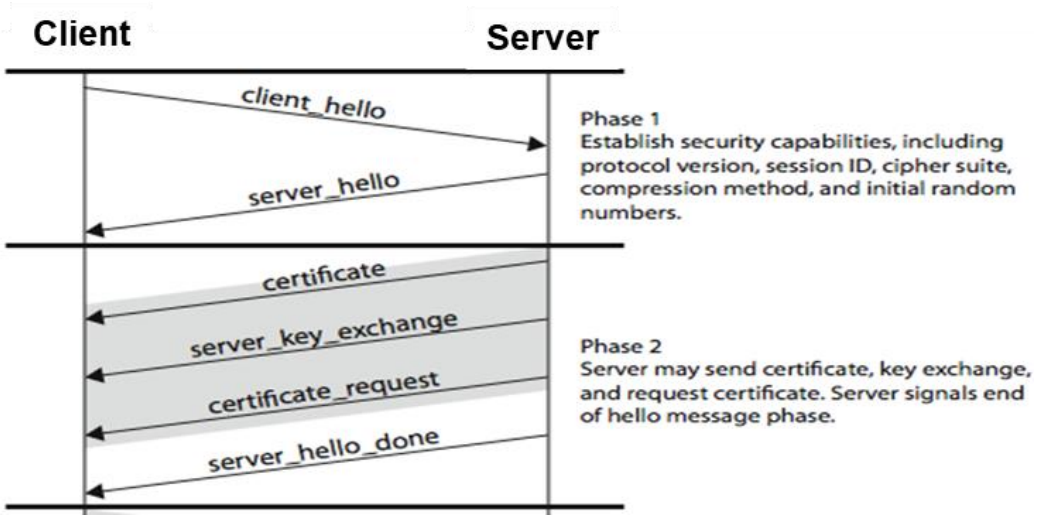
Il protocollo SSL Handshake è costituito da 4 fasi:

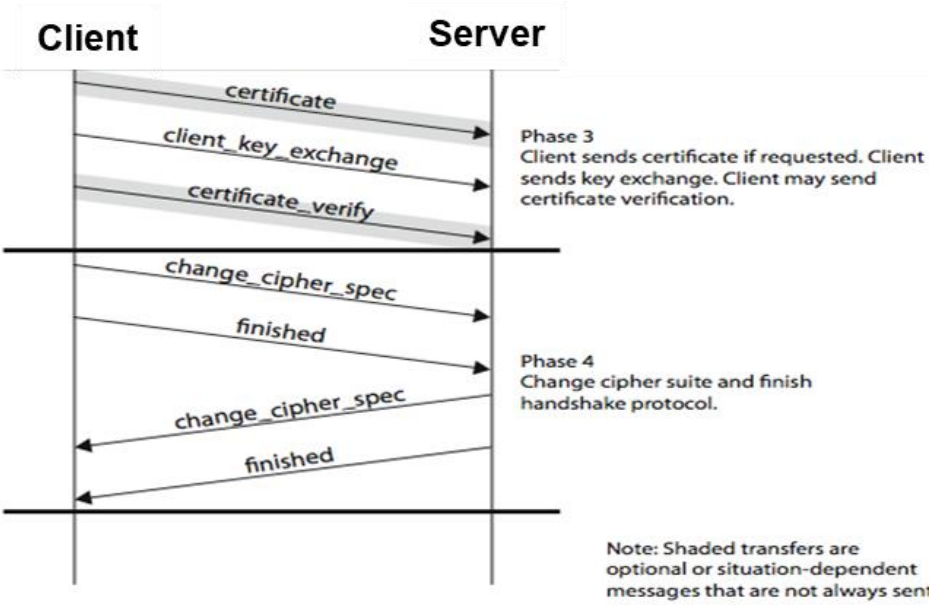
- *Inizializzazione delle funzionalità di sicurezza*
- *Autenticazione del server e scambio delle chiavi*
- *Autenticazione del client e scambio delle chiavi*
- *Fine*

PEGASO Università Telematica

*Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).*

Nelle due figure di seguito sono in sequenza rappresentate queste quattro fasi del protocollo.




*Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).*

# Bibliografia


- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: Capitoli 17.
- "Cryptography and Network Security", 7/ed, William Stallings, Pearson.


PEGASO
Università Telematica

*Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).*